

Linux Hardening & Security Auditing Report

Framework for Eliminating Local Privilege Escalation Vectors

Document Status	Reference Implementation Guide	Target Platforms	Debian / Ubuntu / RHEL Systems
Core Objective	Local Privilege Escalation (LPE) Mitigation	Recommended Tool	Lynis Configuration Auditor

1. Introduction & Core Objective

Proper Linux operating system hardening is the primary administrative defense required to eliminate opportunities for local privilege escalation (LPE). Without defensive constraints, unprivileged users or compromised low-level services can exploit software discrepancies, permission flows, and weak operational hygiene to acquire absolute `root` administrative privileges. This report defines foundational security requirements across updates, configurations, identity management, and systematic auditing.

2. Patch Management & System Updates

Outdated Linux kernels and unpatched third-party service architectures provide deterministic vectors for exploit implementation. Regular patch deployment removes systemic entry points.

- **Debian / Ubuntu Environments:** The default `unattended-upgrades` package handles autonomous security patching. It can be implemented across historic distributions to manage routine package lifecycles automatically.
- **Red Hat Enterprise Linux (RHEL):** The `yum-cron` platform fulfills identical tasks, delivering systemic package tracking and patch execution via defined crontabs.

3. Configuration Management Best Practices

System architectures should maintain minimal operational surface boundaries. At a minimum, configuration baselines must enforce the following controls:

- **SUID/SGID Audit:** Frequently review globally writable assets, directory containers, and binaries configured with the SUID bit to limit untrusted execution context switches.
- **Absolute Binary Paths:** Explicitly declare the fully qualified path for all executable files mapped inside cron schedules or `/etc/sudoers` allocations to prevent relative path manipulation or execution hijacking.
- **Credential Hygiene:** Restrict cleartext password exposure within world-readable files or initialization configurations. Enforce strict cleanup profiles on legacy `.bash_history` listings and home workspaces.

- **Library Protection:** Restrict low-privileged accounts from modifying shared runtime code repositories or custom libraries called by elevated applications.
- **Mandatory Access Controls (MAC):** Implement system security frameworks like SELinux to apply strict object controls beyond standard discretionary permission definitions.

Fleet Automation and Remediation

Organizations can deploy automated tooling frameworks (such as Puppet, SaltStack, Zabbix, or Nagios) to enforce configuration profiles across host clusters. Platforms like Zabbix support file integrity checks via tracking modules (e.g., `vfs.file.cksum`) to monitor sensitive binaries for unauthorized changes.

4. User & Identity Management

Identity security depends on strict adherence to the Principle of Least Privilege and rigorous password management policies:

- **Account Limitation:** Enforce minimal administrative profile populations and record all successful and failed authentication attempts via system audit logs.
- **Authentication Strength:** Enforce strong, high-entropy passphrases rather than relying purely on frequent expiration cycles. Use Pluggable Authentication Modules (PAM) alongside `/etc/security/opasswd` to block password reuse.
- **Group Auditing:** Ensure user memberships do not inherit excessive administrative rights or bridge onto broad infrastructure control groups (such as the `adm` or `docker` groups).

5. Automated Security Auditing via Lynis

Manual reviews should be supplemented by automated configuration compliance tools like **Lynis**. Lynis acts as a modular system scanner that benchmarks operating systems against standard defensive baselines (e.g., DISA STIGs, ISO27001, PCI-DSS).

Example Profile Auditing Sequence:

```
htb_student@NIX02:~$ ./lynis audit system
[ Lynis 3.0.1 ]
#####
NON-PRIVILEGED SCAN MODE
#####
- Detecting OS... [ DONE ]
- Checking profiles... [ DONE ]
-----
Program version:      3.0.1
Operating system:     Linux | Ubuntu 16.04
Kernel version:       4.4.0
Hostname:             NIX02
```

Scan Vulnerability Findings & Output Logs:

Lynis isolates system anomalies into explicit warnings and remediation suggestions:

Warnings (2):

- ! Found one or more cronjob files with incorrect file permissions [SCHED-7704]
- ! systemd-timesyncd never successfully synchronized time [TIME-3185]

Suggestions (53):

- * Set a password on GRUB boot loader to prevent altering boot configuration [BOOT-5122]
- * If not required, consider explicit disabling of core dump in limits.conf [KRN-5820]
- * Run pwck manually and correct any errors in the password file [AUTH-9228]
- * Configure minimum encryption algorithm rounds in /etc/login.defs [AUTH-9230]

Security Index Profiling:

The assessment consolidates the host metrics into a single numeric performance indicator:

Lynis security scan details:

```
Hardening index : 60 [#####          ]
Tests performed : 256
Plugins enabled : 2
```

Files:

```
- Test and debug information      : /home/mrb3n/lynis.log
- Report data                    : /home/mrb3n/lynis-report.dat
```

6. Conclusion

System auditing tools provide an excellent initial baseline, but automated checklists cannot entirely replace hands-on penetration testing and targeted configuration analysis. A resilient security infrastructure must combine automated patch management, strict least-privilege access rules, and proactive system hardening tailored specifically to the data being processed.